DFRWS'12 / Aug 5-8 2012 / Washington DC

Content triage with similarity digests: The M57 case study

THE UNIVERSITY of NEW ORLEANS

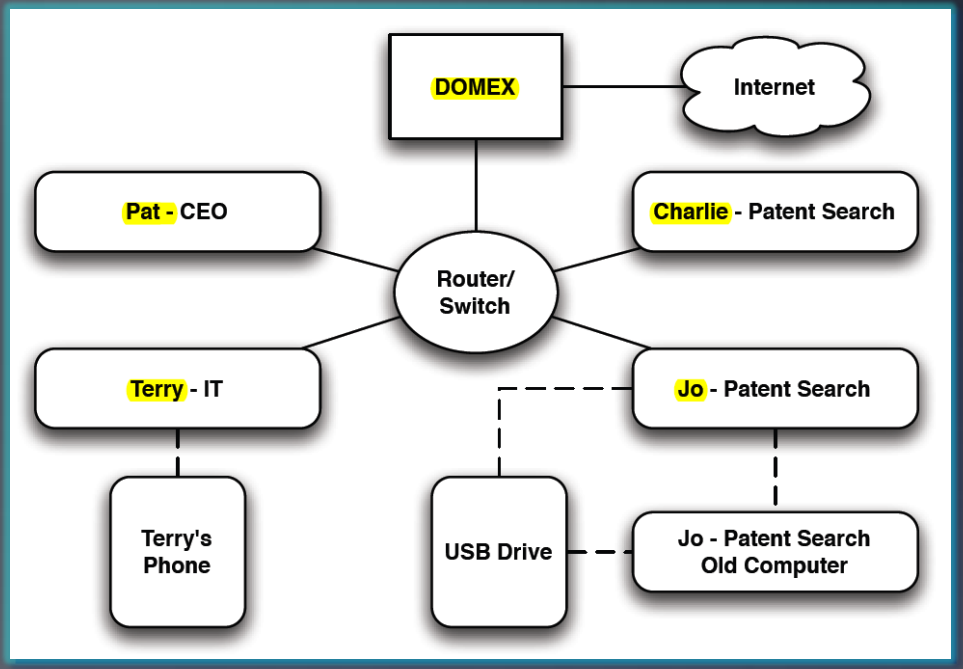
Vassil Roussev

Candice Quates

The M57 Case Study

Introduction

M57: The company & setup



- Employees:
  - President: Pat McGoo
  - IT: Terry
  - Researchers: Jo, Charlie
- Period
  - 11/16/2009—12/11/2009
  - 11/20/2009 Jo's computer replaced
  - Last day: police kick down the door
- Data
  - Daily HDD, RAM, network captures

M57: The data (1.5 TB)

- HDD images
  - 84 images, 10-40GB each
  - Total: **1,423 GB**
- RAM snapshots
  - 78 snapshots, 256-1024 MB each
  - Total: **107 GB**
- Network:
  - 49 traces, 4.6 GB
- USB
  - 4.1 GB
- Kitty set
  - 125 JPEGs, 224 MB

Scenario #1: Contraband

- Setup:
  - From the detective reports in the scenario, there is reason to suspect that one of M57's computers (Jo's) has been used in the contraband of "kitty porn".
- Questions:
  - Were any M57 computers used in contraband?
  - If so, when did the accident happen?
  - Is there evidence of intent?
  - How was the content distributed?
  - Was any of the content sent outside the company network?

Scenario #2: Eavesdropping

- Setup:
  - It is suspected that somebody is spying on the CEO (Pat) electronically.
- Plan?
  - Search for potentially rogue processes that might have been introduced on his computer.
  - First HDD image is clean and serves as baseline.

Scenario #3: Corporate espionage

- Setup:
  - There is suspicion that somebody has leaked company secrets.
- Plan?
  - Search RAM snapshots for interesting processes

The need for better triage

Triage

- ***Fast, reliable*** initial screen of the acquired data:
  - *fast:* all you can do in 5/10/15/ … min;
  - *reliable:* provides *strong hints* (low FP).
- Goals:
  - Identify the most (ir)relevant targets/artifacts;
  - Build an overall understanding of the case—what are the likely answers?
- Location of work:
  - We assume post-acquisition work in a lab, but
  - It could be done in the field (given enough hardware)

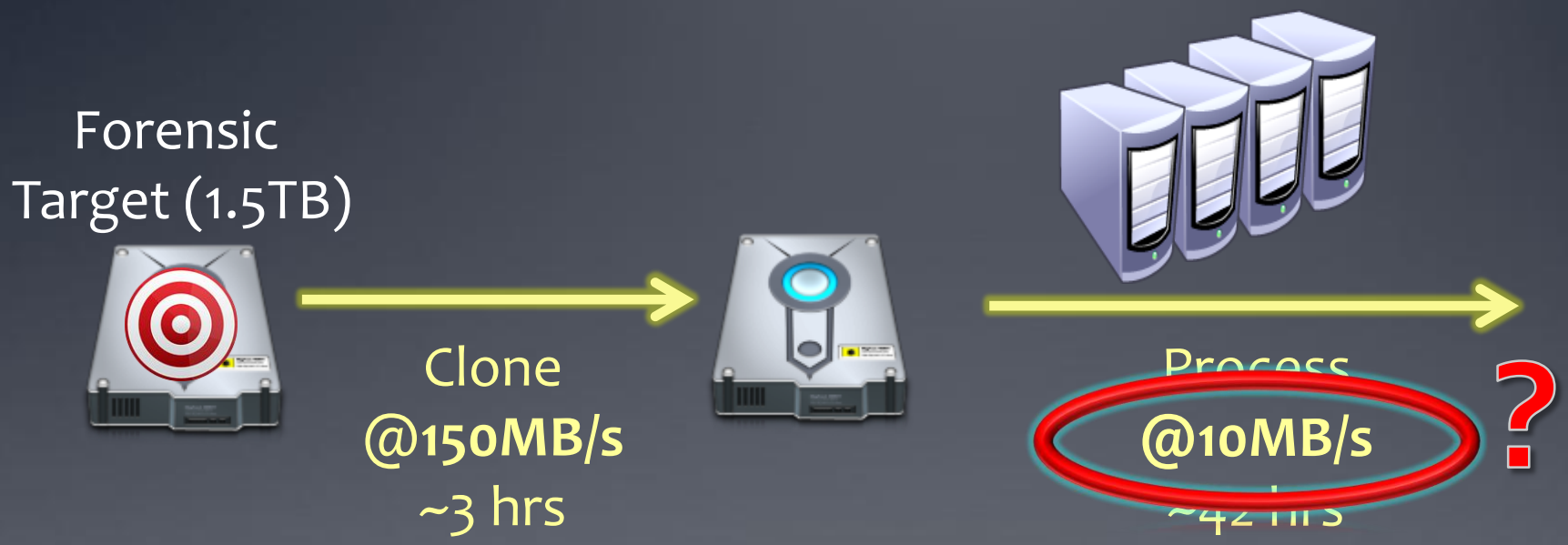
Metadata- vs content-based analysis

- Metadata-based analysis
  - Use FS metadata, registry, logs, etc.
  - Pro: small volume, high-level logical information
  - Con: not looking at the data, cannot see remnants, does not work on a data dump (e.g. RAM), metadata is fragile

  ➔ Typical basis for (manual) triage
- Content analysis
  - Works on actual data content
    - Flie/block hashes, indexing, carving, etc.
  - Pro: looking at actual data, can work with pieces
  - Con: large volume, lower level data

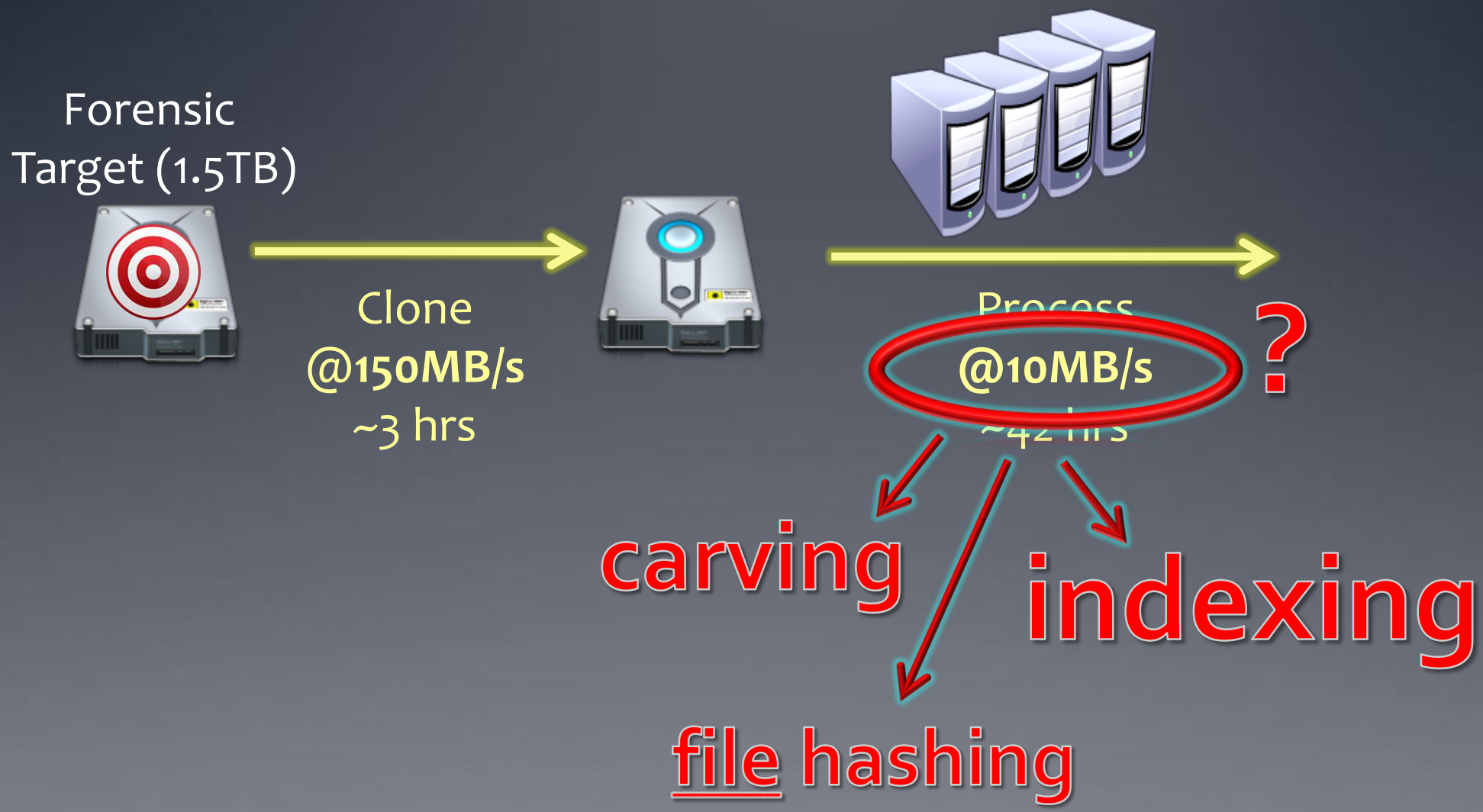
  ➔ Almost never used in triage (perceived as too slow)

Why is content analysis so slow?

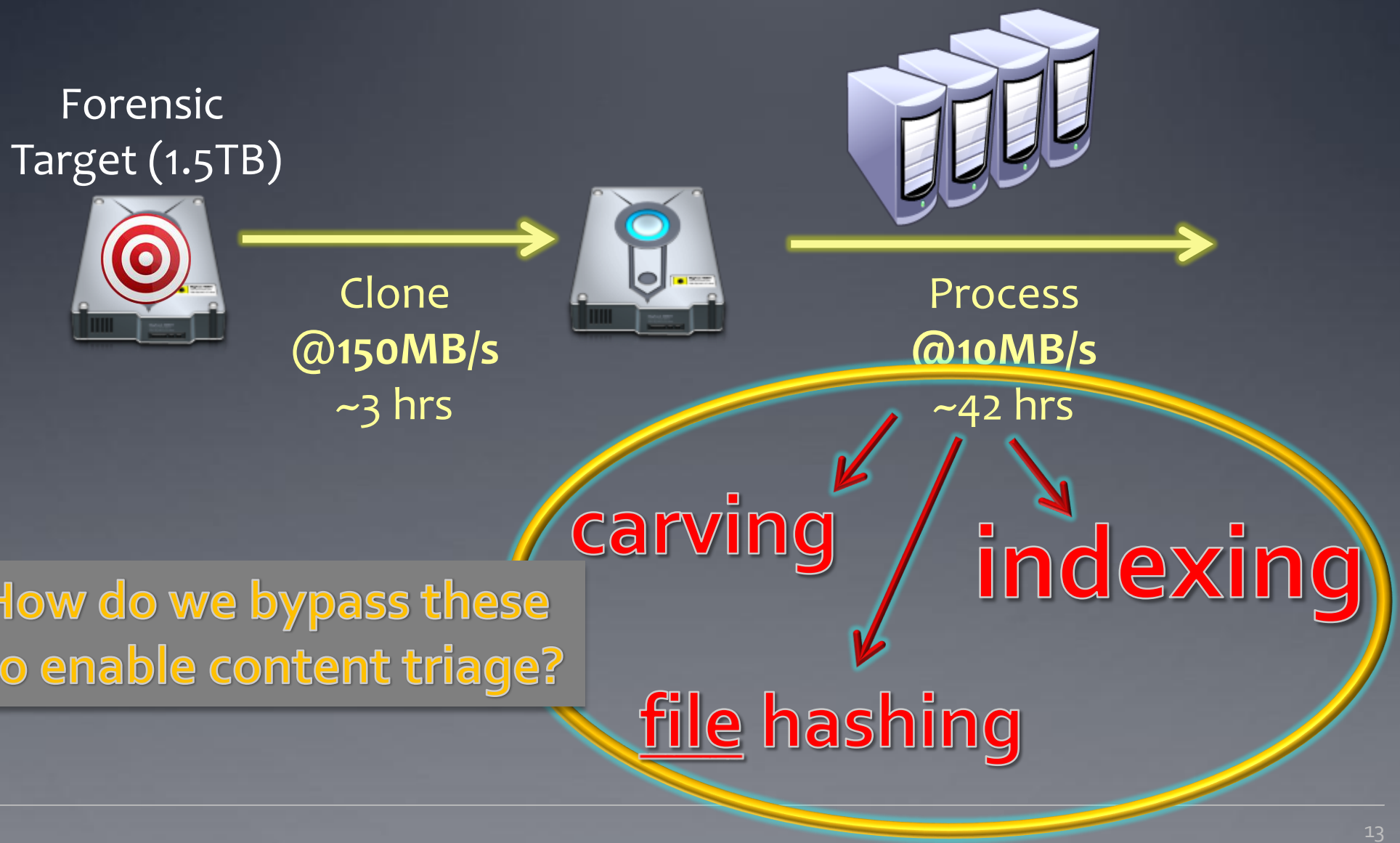


➔ We can ***start*** working on the case after 42 hours (!)

Why is content analysis so slow?



Why is content analysis so slow?



How do we bypass these to enable content triage?

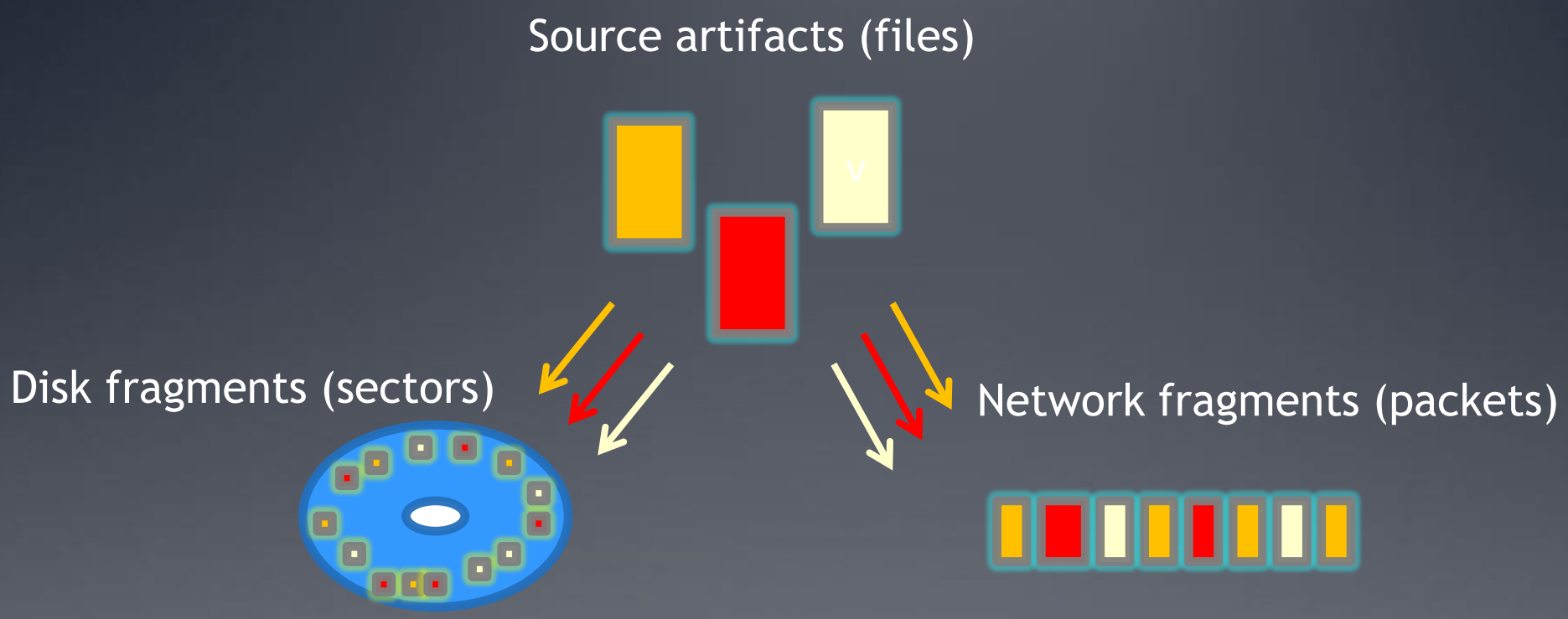
Data Correlation

with similarity digests

Motivation for similarity approach: *Traditional hash filtering is failing*

- *Known file filtering:*
  - Crypto-hash known files, store in library (e.g. NSRL)
  - Hash files on target
  - Filter in/out depending on interest
- Challenges
  - Static libraries are falling behind
    - Dynamic software updates, trivial artifact transformations
    - ➔ We need **version** correlation
  - Need to find embedded objects
    - Block/file in file/volume/network trace
  - Need higher-level correlations
    - Disk-to-RAM
    - Disk-to-network

Scenario #1: fragment identification



- Given a fragment, identify source
  - ***Minimum*** fragments of interest are 1-4KB in size
  - Fragment ***alignment is arbitrary***

Scenario #2: artifact similarity

Bringing science to digital forensics with standardized forensic corpora

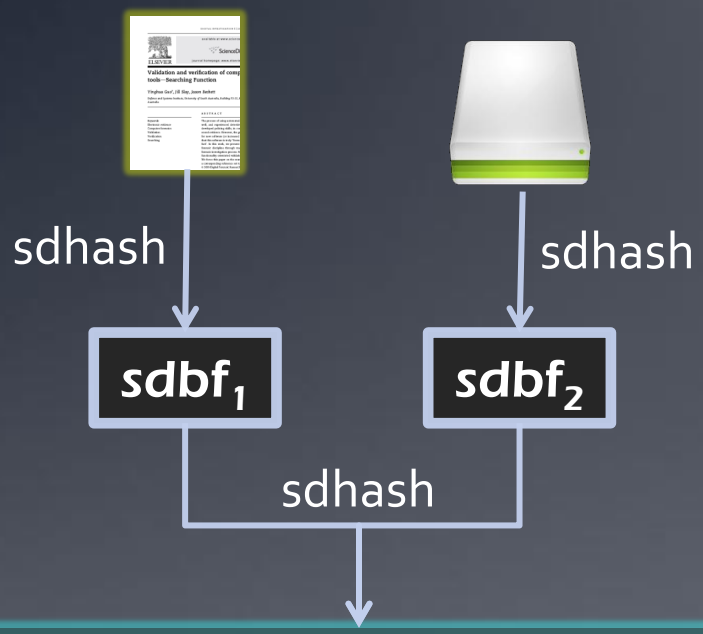
Validation and verification of computer forensic software tools—Searching Function

Similar files
(shared content/format)

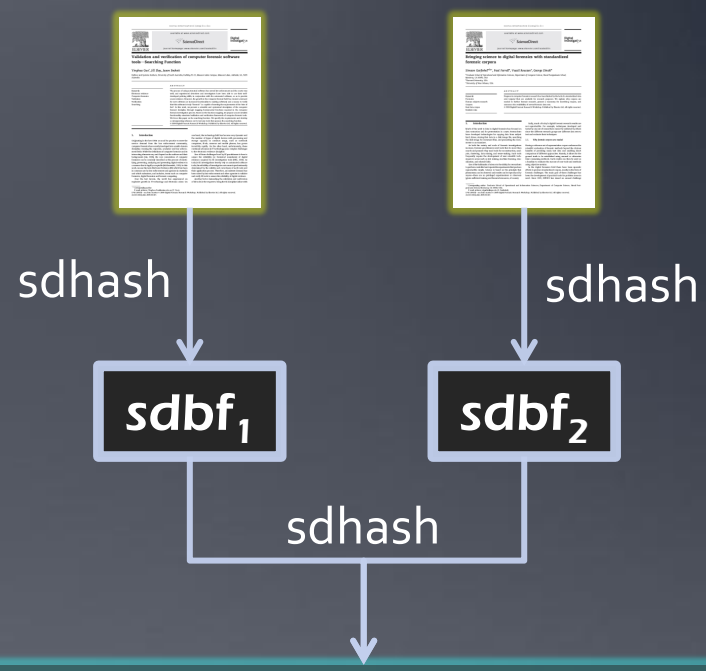
Similar drives
(shared blocks/files)

- Given two binary objects, detect similarity/versioning
  - Similarity here is purely syntactic;
  - Relies on commonality of the binary representations.

Common solution: similarity digests



Is this fragment present on the drive?
➔ 0 .. 100



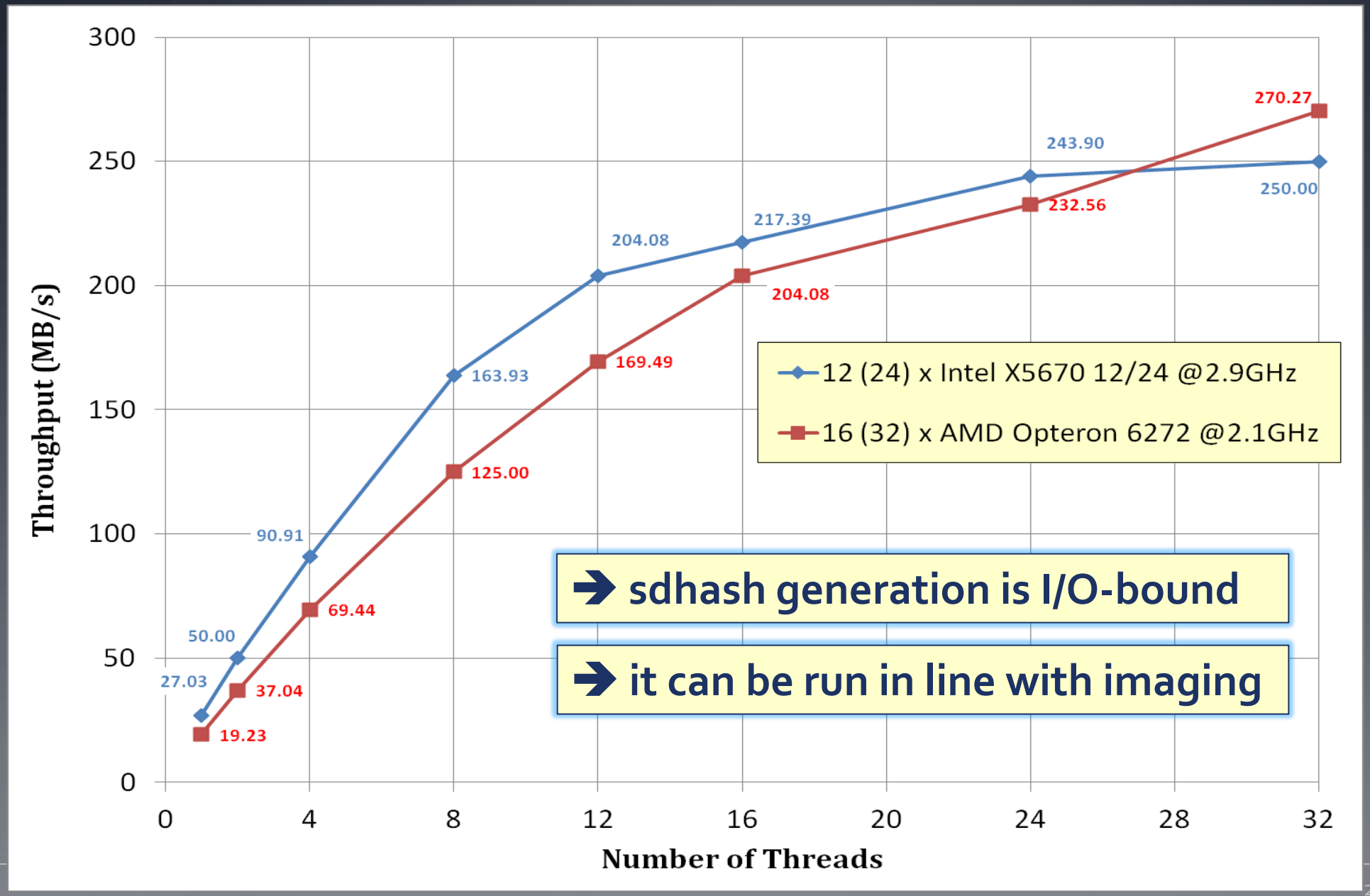
Are these artifacts correlated?
➔ 0 .. 100

All correlations based on bitstream commonality

The M57 Case Study

Using sdhash for triage

sdhash-2.2 generation rates



➔ sdhash generation is I/O-bound

➔ it can be run in line with imaging

sdhash generation times (M57)

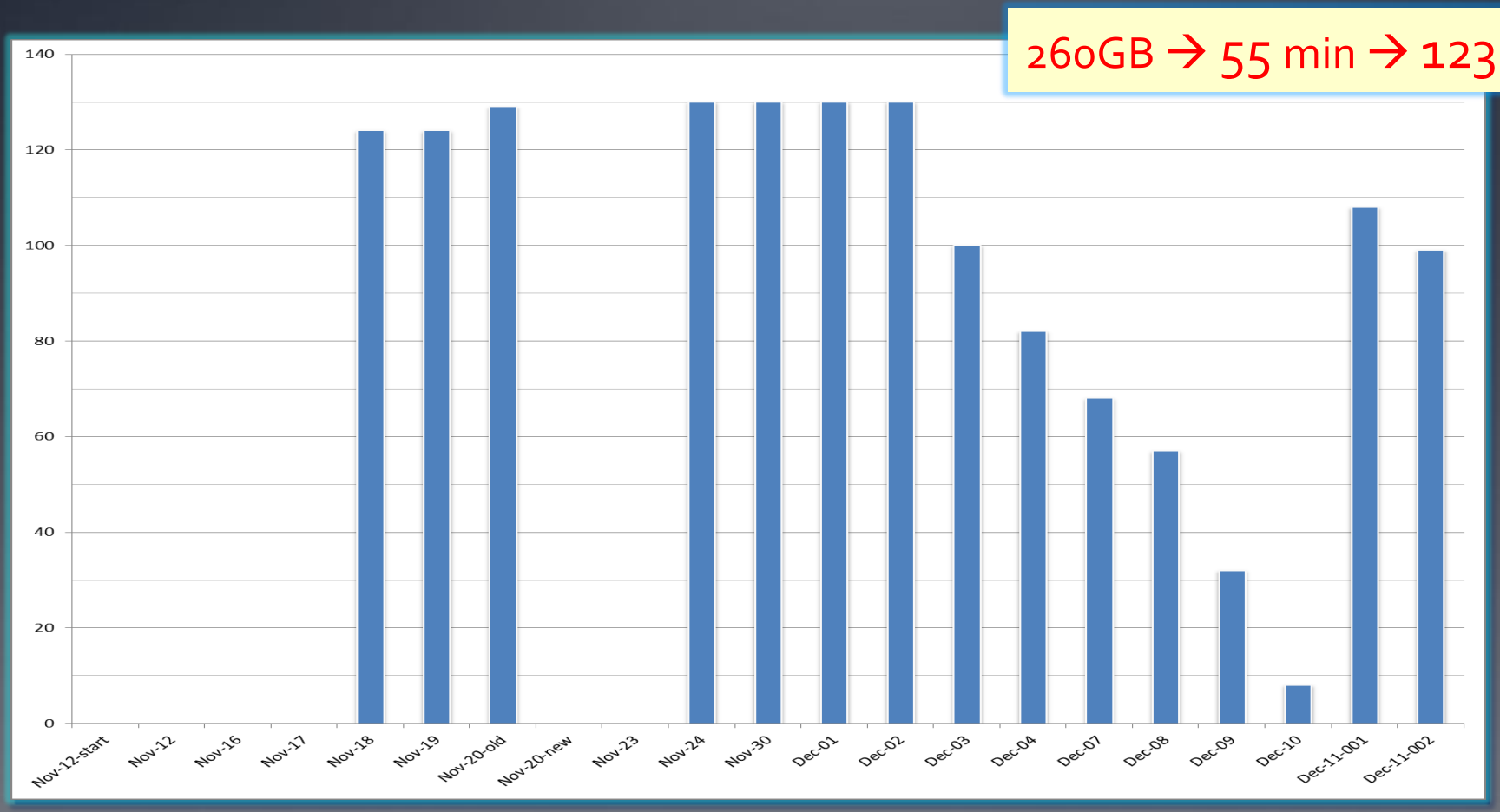
Data Set	Size (GB)	Time (min)	Rate (MB/s)
HDD	1,423.0	168.00	143
RAM	107.0	10.70	166
Network	4.6	0.40	196
USB disk	4.1	0.45	155
Kitty	0.2	0.08	45
Total	**1,538.9**	**179.63**	**143**

- Dell PowerEdge R710 server
  - 2 x Intel Xeon CPUs @2.93GHz six-core with H/T 12(24) threads
  - 72GiB of RAM @800MHz

Scenario #1: Contraband

- Setup:
  - From the detective reports in the scenario, there is reason to suspect that one of M57's computers (Jo's) has been used in the contraband of "kitty porn".
- Questions:
  - Were any M57 computers used in contraband?
  - If so, when did the accident happen?
  - Is there evidence of intent?
  - How was the content distributed?
  - Was any of the content sent outside the company network?

Query 1: Search Jo's HDD for kitty images



Jo's computer: Number of instances found by date

Query 2: What processes were running?

- Search Jo's RAM for traces of installed executables

18 min

```
12/03
.../Downloads/TrueCrypt Setup 6.3a.exe 092
.../TrueCrypt Format.exe               090
.../TrueCrypt Setup.exe                092
.../TrueCrypt.exe                      092
12/04
.../Downloads/TrueCrypt Setup 6.3a.exe 063
.../TrueCrypt Setup.exe                063
12/09
.../Downloads/TrueCrypt Setup 6.3a.exe 084
.../TrueCrypt Format.exe               079
.../TrueCrypt Setup.exe                084
.../TrueCrypt.exe                      090
12/10
.../TrueCrypt.exe                      092
12/11 - pre-raid
.../TrueCrypt Format.exe               086
.../TrueCrypt.exe                      079
```

Scenario #2: Eavesdropping

- Setup:
  - It is suspected that somebody is spying on the CEO (Pat) electronically.
- Plan?
  - Search for potentially rogue processes that might have been introduced on his computer.
  - First HDD image is clean and serves as baseline.

Eavesdropping timeline

20 min

```
11/16, [71] not in baseline
  Present: Java, Firefox, python, mdd_1.3.exe.

11/19, [95] not in baseline
  Acrobat Reader 9 installed or updated,
  including Adobe Air.
  18 other programs from 11/16 still present.

11/20, [289]
  Windows Update run: many new dlls in the
  _restore and SoftwareDistribution folders.

11/23, [561]
  Windows Update has run

11/30, [274]
  Likely a Brother printer driver installed.
  Acrobat/Firefox still present.
```

```
12/03, [649]
  AVG has been updated.
  XP Advanced Keylogger appears:
    XP Advanced/DLLs/ToolKeyloggerDLL.dll 087
    XP Advanced/SkinMagic.dll             027
    XP Advanced/ToolKeylogger.exe         024
12/07, [460]
  More Brother printer related files.
  InstallShield leftovers present.
  win32dd present.
  XP Advanced Keylogger is no longer here.
  RealVNC VNC4 has been installed and run:
    RealVNC/VNC4/logmessages.dll 068
    RealVNC/VNC4/winvnc4.exe     046
    RealVNC/VNC4/wm_hooks.dll    023

12/10, [1240]
  AVG updated.
  IE8 and Windows updated.
  VNC still present.

12/11, [634]
  VNC present.
```

Scenario #3: Corporate espionage

- Setup:
  - There is suspicion that somebody has leaked company secrets.
- Plan?
  - Search RAM snapshots for interesting processes

Scenario #3: Findings

31 min

- RAM
  - "Cygnus FREE EDITION" hex editor
    - On 11/24, 11/30, 12/02, 12/03, and 12/10;
  - "Invisible Secrets 2.1"
    - 11/19, 11/20, 11/24, 11/30, and 12/02.
    - `blowfish.dll, jpgcarrier.dll, bmpcarrier.dll`

    ➔ likely stego tool
- USB
  - `insecr2.exe`
  - `/microscope.jpg`
  - `/microscope1.jpg`
  - `/astronaut.jpg`
  - `/astronaut1.jpg`
  - `/Email/Charlie_..._Sent_astronaut1.jpg`
  - `/Email/other/Charlie_..._Sent_microscope1.jpg`

M57 Conclusions

- Using `sdhash`, we can outline the solution of all three cases in about **120 min** of extra processing.
  - This assumes HDD/RAM hash generation while cloning.
  - This could be further improved by running the queries in R/T in parallel with acquisition.
- The tool enables differential analysis that is simple, fast, robust, and generic.
  - ➔ Most processing can run in parallel with acquisition.
  - ➔ In effect, it can replace carving/indexing during triage.
  - ➔ It does not require much expertise to apply; results are intuitive.
  - ➔ The analysis can be highly automated; higher-level analysis can be built on top.